

Task 2: Web Application Security Basics

1. Task Explanation

Web application security testing was performed on a safe and authorized DVWA (Damn Vulnerable Web Application) environment through TryHackMe.

The application was tested for two common web vulnerabilities:

- SQL Injection
- Cross-Site Scripting (XSS)

Burp Suite was used to intercept and inspect HTTP requests generated during the testing. The purpose was to understand how vulnerable applications handle user input and to identify the associated security risks.

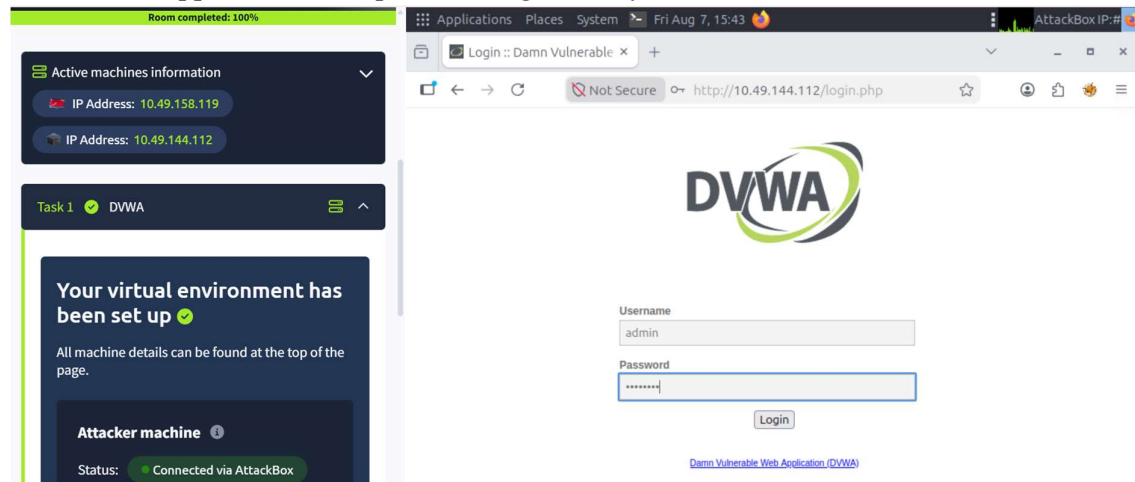
2. Tools Used

- TryHackMe
- DVWA (Damn Vulnerable Web Application)
- Burp Suite Community Edition
- Firefox Browser
- Linux AttackBox

3. Procedure

Step 1: Access DVWA

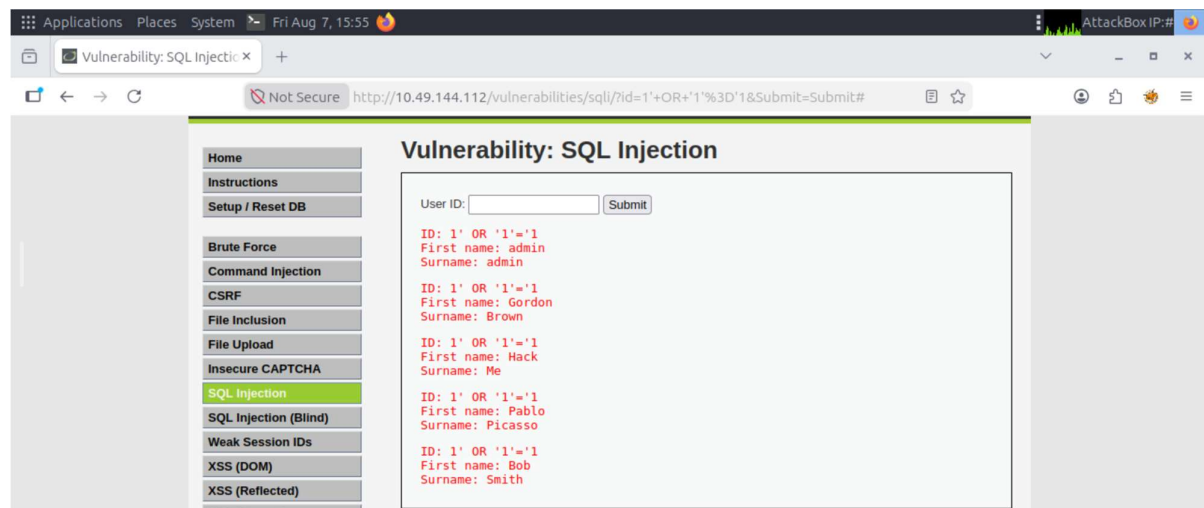
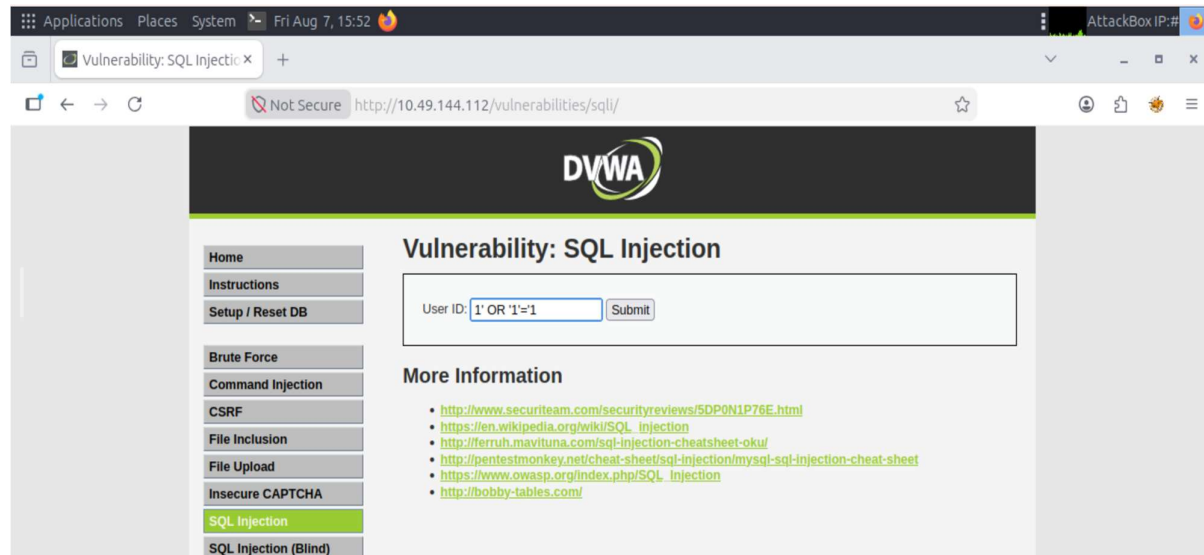
The DVWA application was opened through the TryHackMe environment.



Step 2: Test for SQL Injection

The SQL Injection module in DVWA was opened and a test SQL Injection payload was entered into the input field.

The application response was observed to determine whether the input could manipulate the underlying SQL query.



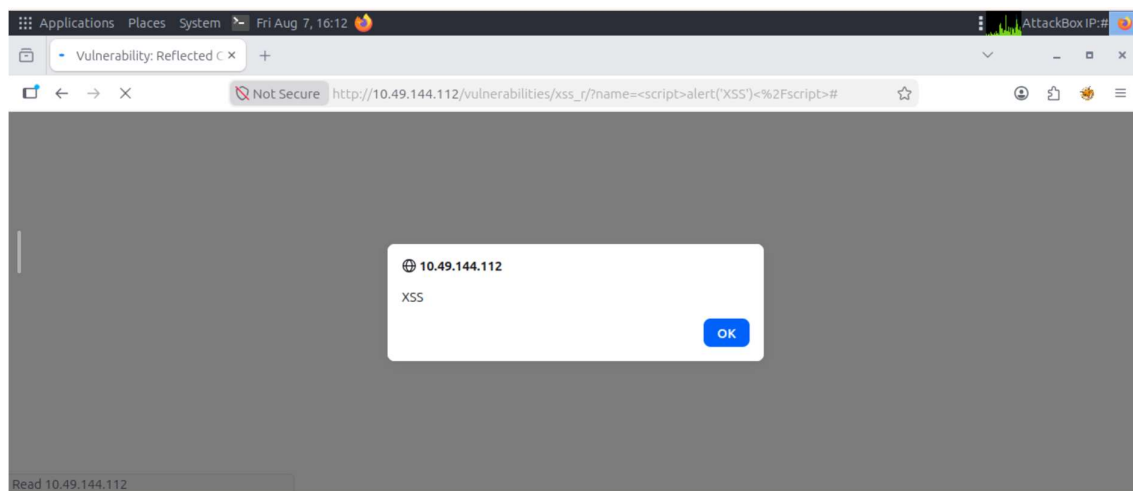
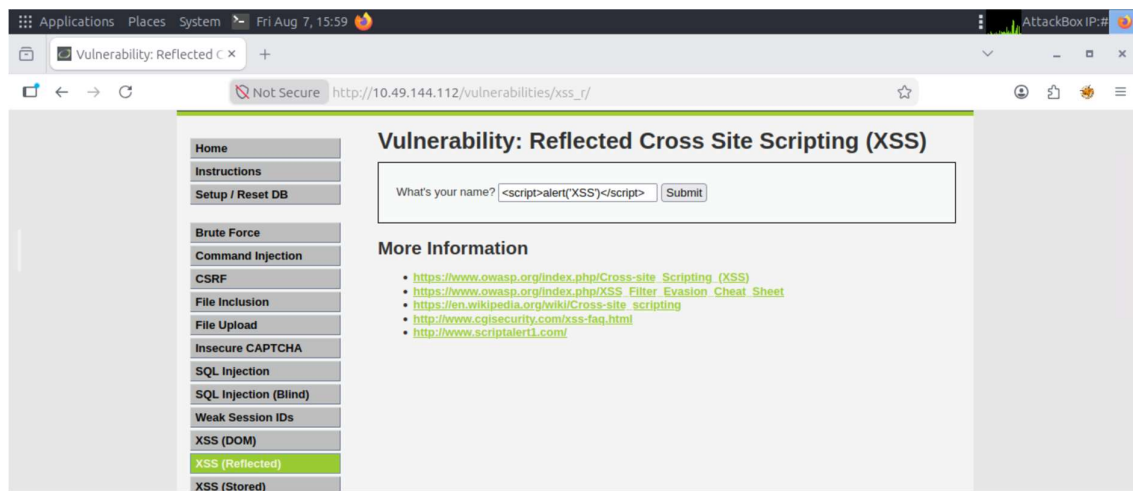
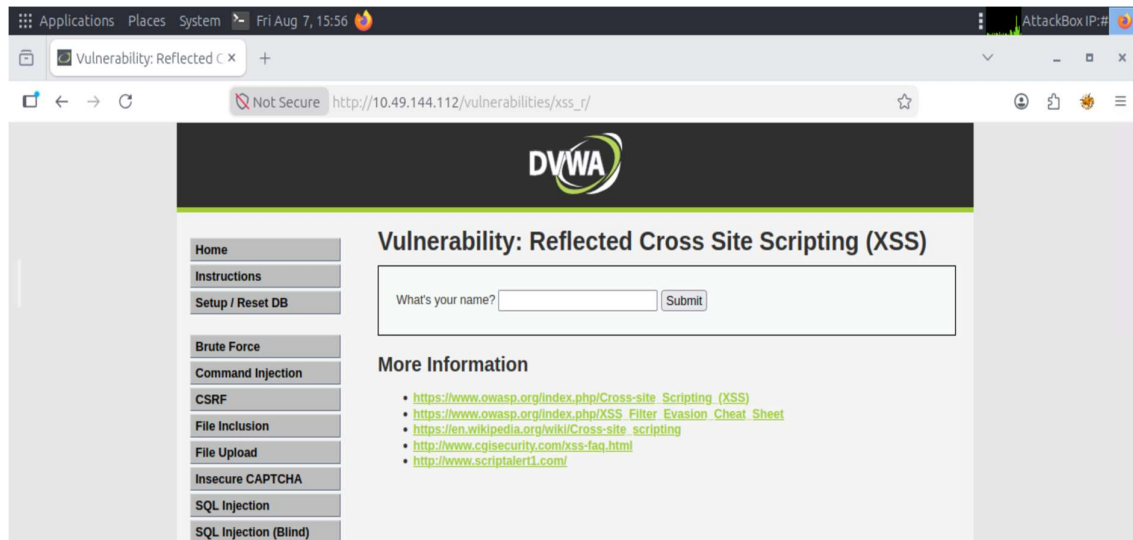
Step 3: Test for Cross-Site Scripting

The Reflected XSS module in DVWA was opened. A test XSS payload was entered into the input field.

Example:

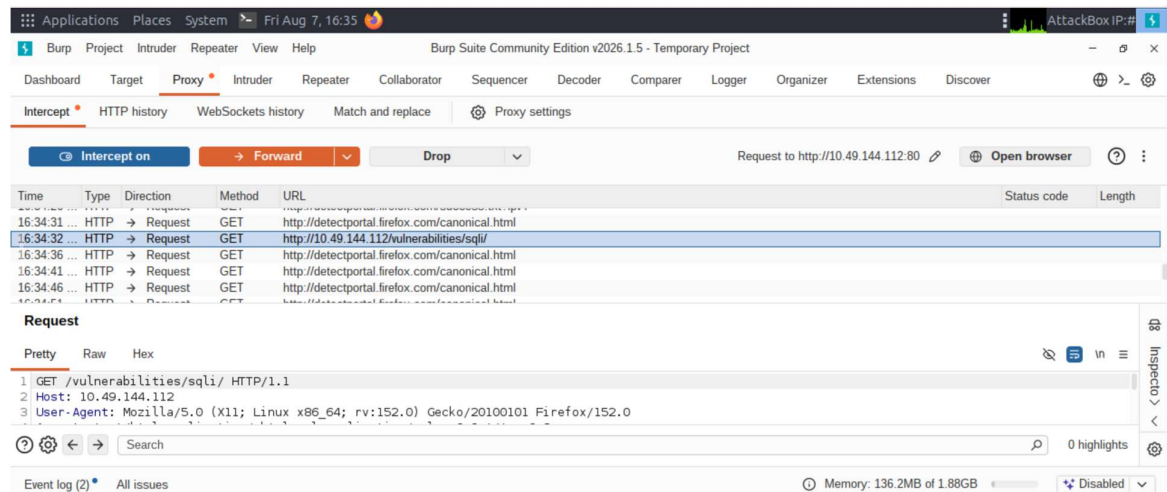
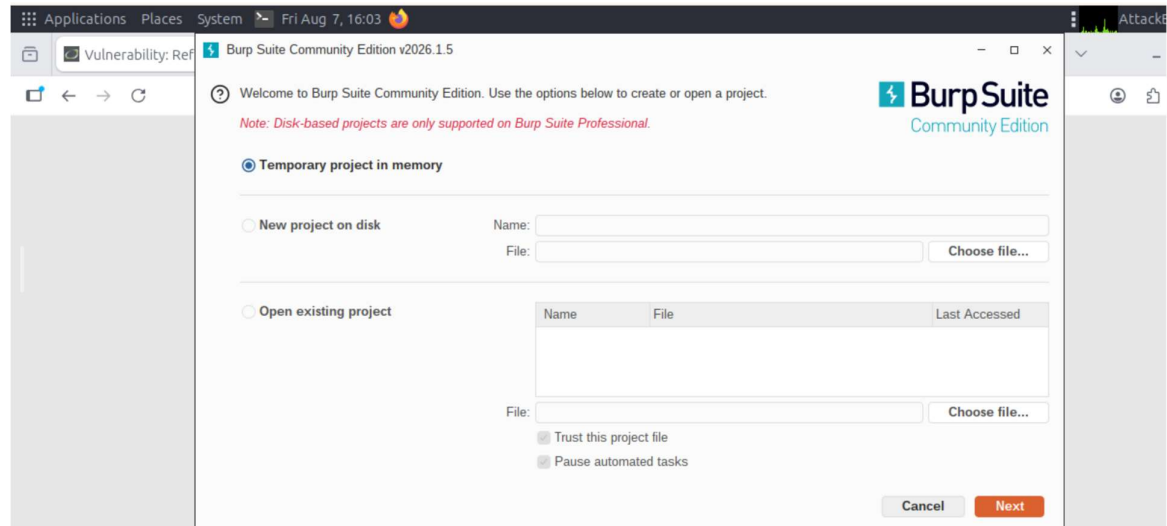
```
<script>alert('XSS')</script>
```

The application response was observed to determine whether the input was reflected and executed.



Step 4: Intercept Request Using Burp Suite

Burp Suite was used to intercept the HTTP request generated while submitting the test input. The intercepted request was examined to understand how user input was transmitted to the web application.



4. Findings

- The DVWA application was tested for SQL Injection and Reflected XSS.
- SQL Injection testing demonstrated the risk of insecure handling of database input.
- XSS testing demonstrated the risk of allowing untrusted input to be reflected in a web page.
- Burp Suite successfully allowed HTTP requests to be intercepted and inspected.
- The testing was performed in the controlled DVWA environment.

5. Security Risks

SQL Injection

- Unauthorized database access.
- Disclosure of sensitive information.
- Possible modification or deletion of database records.
- Authentication bypass in vulnerable applications.

Cross-Site Scripting

- Execution of malicious JavaScript in a victim's browser.
- Session or cookie theft in vulnerable configurations.
- Modification of displayed web content.
- Phishing or malicious redirection.

Mitigation Recommendations

SQL Injection

- Use prepared statements and parameterized queries.
- Validate and sanitize all user inputs.
- Apply the principle of least privilege to database accounts.
- Avoid constructing SQL queries using user input directly.
- Perform regular vulnerability assessments and security testing.

Cross-Site Scripting (XSS)

- Validate and sanitize all user inputs.
- Encode output before displaying user-generated content.
- Implement a Content Security Policy (CSP).
- Use HTTPOnly and Secure cookie attributes.
- Keep web application frameworks and libraries updated.
- Perform regular security testing to identify and fix vulnerabilities.

7. Result

SQL Injection and Reflected XSS testing was successfully performed in the authorized DVWA environment. Burp Suite was used to intercept and inspect HTTP requests. The security risks associated with both vulnerabilities were identified and appropriate mitigation techniques were recommended.